



PRIVILEGED ACCESS MANAGEMENT · HEALTH CHECK

CyberArk Health Check Findings & Remediation Report

A structured assessment of privileged access controls, configuration posture, and remediation priorities.

PREPARED FOR	(redacted)
ENGAGEMENT	L3-0427 · CyberArk Health Check
PREPARED BY	Link3IT — a practice of LJSTECH LLC
SCOPE	Vault, CPM, PSM, PVWA, platform policies, safe design
CLASSIFICATION	Confidential — Client & Link3IT only
STATUS	Sample / illustrative deliverable

This is a redacted sample. All client identifiers, hostnames, and account details have been removed or fabricated for illustration. It demonstrates the structure, depth, and clarity of a Link3IT deliverable — not a real client environment.

Executive Summary

This health check assessed the organization's CyberArk deployment against leading practice across vault configuration, credential rotation, session management, and least-privilege design. The environment is functional and broadly well-architected, but credential rotation and safe-membership discipline have drifted in ways that materially increase privileged-access risk.

62/100

PRIVILEGED ACCESS POSTURE

TIER: MANAGED

Headline: Of 31 findings, 3 are Critical and 9 are High. The Critical findings concentrate in credential rotation — accounts that appear managed but are not rotating — and over-broad access to tier-0 safes. None require platform re-architecture; all are remediable with configuration and process change.

Fastest risk reduction: restoring CPM reconciliation and re-baselining safe membership would close both Critical rotation findings and roughly 40% of total weighted risk within the first remediation phase.

SEVERITY	COUNT	REPRESENTATIVE THEME
CRITICAL	3	Unrotated managed credentials; tier-0 safe exposure
HIGH	9	Over-permissive membership; incomplete session recording
MEDIUM	13	Policy consistency; platform tuning; logging gaps
LOW	6	Documentation; naming; housekeeping

SECTION 2

Scope & Methodology

Findings were derived from read-only configuration evidence collected directly from the platform over a defined assessment window. Each finding is grounded in observed configuration state, not interview alone, and is assessed against published hardening guidance (CIS Controls v8, NIST SP 800-53 AC/IA families) and vendor leading practice.

In scope

- Vault configuration, safe design, and access control
- Central Policy Manager (CPM) — rotation and reconciliation health
- Privileged Session Manager (PSM) — recording and isolation coverage
- Password Vault Web Access (PVWA) — access and authentication
- Platform and master policy consistency

Out of scope

Endpoint privilege management (EPM), application-level secrets, and network architecture were excluded from this engagement by agreement during scoping.

SECTION 3

Priority Findings (Detail)

Excerpt: 4 of 31 findings shown. Each finding in the full report includes observation, risk, evidence reference, and remediation.

PAM-01 **CRITICAL** CPM reconciliation failing on 14 managed accounts

OBSERVATION

14 accounts across two safes are marked as managed but show a last-successful-rotation date exceeding 90 days. The configured reconciliation account lacks the rights required to reset target credentials, so failed verifications never self-heal.

RISK

A credential believed to be rotating is, in practice, static. If any of these passwords were exposed prior to vaulting, that exposure persists indefinitely — defeating the core control PAM is meant to provide.

REMEDIATION

Grant the reconciliation account the required reset rights on target systems; force a reconcile cycle; add monitoring that alerts when any managed account exceeds its rotation interval.

PAM-04 **CRITICAL** Over-permissive membership on Domain-Admin safe

OBSERVATION

23 user accounts hold retrieve rights to the safe containing Domain Administrator credentials, several via nested group membership that appears unintentional. Tier-0 access is not restricted to a minimal, named set.

RISK

The blast radius of any one of those 23 accounts being compromised includes full domain administrative credentials. Least privilege is not enforced where it matters most.

REMEDIATION

Re-baseline safe membership to a named, justified set; remove nested-group grants; require dual control for tier-0 retrieval.

IAM-02 **HIGH** Session recording gaps on a subset of PSM connections

OBSERVATION

A class of connection components is configured to bypass PSM, so privileged sessions on those targets are neither isolated nor recorded.

RISK

Privileged activity on affected targets cannot be reconstructed for audit or incident response — a gap auditors increasingly flag.

REMEDIATION

Route the affected targets through PSM; where direct access is genuinely required, document a compensating control and time-box the exception.

AD-03**MEDIUM****Service accounts with Kerberoast exposure****OBSERVATION**

Three service-principal-bound accounts use passwords below current strength guidance and are not vault-managed.

RISK

These accounts can be targeted offline (Kerberoasting), providing a quiet path to credential compromise and escalation.

REMEDIATION

Onboard the accounts to CPM management with strong, rotated passwords; where possible migrate to group-managed service accounts.

SECTION 4

Remediation Roadmap

Sequenced by risk reduction per unit of effort — the work that removes the most risk fastest comes first.

Phase 1 · 0–30 days · Contain

ACTION	CLOSES	EFFORT	OWNER
Restore CPM reconciliation; force rotation cycle	PAM-01	Low	PAM team
Re-baseline Domain-Admin safe membership	PAM-04	Low	PAM + IAM
Add rotation-interval alerting	PAM-01, +2	Medium	PAM team

Phase 2 · 30–90 days · Harden

ACTION	CLOSES	EFFORT	OWNER
Route bypassed targets through PSM	IAM-02	Medium	PAM team
Onboard Kerberoastable service accounts	AD-03, +1	Medium	AD + PAM
Reconcile master vs. platform policy drift	5 Medium	Medium	PAM team

Phase 3 · 90+ days · Sustain

ACTION	CLOSES	EFFORT	OWNER
Dual control for tier-0 retrieval	PAM-04 (hardening)	Medium	IAM governance
Quarterly safe-membership review cycle	Process	Low	IAM governance
Documentation & naming remediation	6 Low	Low	PAM team

How to read this roadmap. Phase 1 is deliberately low-effort and high-impact: it closes both Critical findings using configuration and access change alone, with no platform downtime. Phases 2 and 3 progressively harden and then institutionalize the controls so the environment does not drift back.

SECTION 5

Next Steps

Link3IT can support remediation in whichever model fits the organization: hands-on alongside the internal team, advisory as the team executes, or a clean hand-off with documentation. There is no lock-in — the report, evidence, and roadmap are the client's to keep and act on independently.

To discuss this report or scope remediation: asymister@link3it.com